

M0 · SECURITY REVIEW

M0

Liquidity Delivery Updates.

A security review of Liquidity Delivery Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
M0	Liquidity Delivery Updates	Guardian	May 19 – May 30, 2026	June 8, 2026

§ 00

Contents.

13 pages — overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 3 findings	P. 08
	Remediation Review · 1 finding	P. 11
§ 05	Disclaimer	P. 12
§ 06	About Guardian	P. 13

§ 01

Overview.

Guardian reviewed Liquidity Delivery Updates across 2 review rounds. The final report includes 1 Low, 3 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	m0-foundation/liquidity-delivery
CLIENT	METHODOLOGY
M0	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
Liquidity Delivery Updates	4ad31c9b13a3
PREPARED BY	REMEDATION REVIEW COMMIT
Guardian	22475fc629b5
AUDIT WINDOW	
May 19 – May 30, 2026	
FINAL REPORT	
June 8, 2026	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	0	0	0	0	0
Low	1	0	0	0	1
Informational	3	0	1	0	2
All severities	4	0	1	0	3

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Liquidity Delivery Updates in `m0-foundation/liquidity-delivery`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
I-01	NatSpec comments are stale	Documentation	INFORMATIONAL	RESOLVED	p. 8
I-02	Gasless cancel cannot be wrapped	Informational	INFORMATIONAL	RESOLVED	p. 9
I-03	Filling native orders may fail	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 10
REMEDIATION REVIEW					
L-01	Cancel TYPEHASH diverges from EIP-712	Compatibility	LOW	RESOLVED	p. 11

INFORMATIONAL I-01

RESOLVED

NatSpec comments are stale

CATEGORY Documentation

LOCATION evm/src/interfaces/IOrderBook.sol:62, evm/src/interfaces/IOrderBook.sol:171, evm/src/interfaces/IOrderBook.sol:205, evm/src/interfaces/IOrderBook.sol:349-351, evm/src/interfaces/IOrderBook.sol:363-365, evm/src/interfaces/IOrderBook.sol:382-384

REVIEW Main Review

DESCRIPTION

Some `IOrderBook` NatSpec comments are stale after recent order-opening changes. `Order.sender` and `OrderData.sender` are documented as the address that provided funds, but `sender` is now the order owner while the `funder / msg.sender` provides tokens. The `cancelOrder()` fee comments also refer to same-chain and cross-chain fills even though the section documents cancellations. Finally, `OrderCompleted` is documented as destination-chain-only, but it can also be emitted by `reportFill()` on the origin chain.

RECOMMENDATION

Update the NatSpec comments to describe `sender` as the order owner, distinguish it from `funder`, replace fill wording with cancel wording in `cancelOrder()` documentation, and clarify where `OrderCompleted` may be emitted.

RESOLUTION

Status: Resolved.

INFORMATIONAL I-02

RESOLVED

Gasless cancel cannot be wrapped

CATEGORY	Informational
LOCATION	https://github.com/GuardianOrg/liquidity-delivery-team1-1779205721766/blob/4ad31c9b13a36ef83a58a7af8a7d01510864f51a/evm/src/OrderBook.sol#L242-L246
REVIEW	Main Review

DESCRIPTION

The removed `cancelOrderFor()` functionality cannot be replicated by a generic wrapper in the same way as gasless `openOrder()` flows. Before the deadline, `cancelOrder()` authorizes cancellation by checking that `msg.sender` is the order `recipient` or, for same-chain orders, the order `sender`. If a wrapper verifies a user signature and calls `cancelOrder()`, `OrderBook` sees the wrapper as `msg.sender`, so the call fails unless the wrapper itself is the authorized address.

Setting the wrapper as `recipient` is not equivalent because fills transfer `tokenOut` directly to `recipient` without executing a callback. The wrapper would become a custody/accounting layer and would need additional forwarding, claiming, or off-chain keeper logic to route filled funds to the actual user.

RECOMMENDATION

Make sure this is intentional. If it's not - consider having the gasless cancel feature back in the `OrderBook`.

RESOLUTION

Status: Resolved.

INFORMATIONAL I-03

ACKNOWLEDGED

Filling native orders may fail

CATEGORY	Warning
LOCATION	https://github.com/GuardianOrg/liquidity-delivery-team1-1779205721766/blob/4ad31c9b13a36ef83a58a7af8a7d01510864f51a/svm/programs/order_book/src/instructions/fill.rs#L82-L159
REVIEW	Main Review

DESCRIPTION

After compiling the orderbook, the `FillNativeOrder` tests should be checked for success.

Currently, the plan is to compile the program using Solana v2.1.0 and Anchor v0.31.1. However, for different versions of the toolchain, the following issue may materialize:

The SVM `FillNativeOrder` account context is too large for SBF stack limits. During `anchor build`, the compiler reports that the generated `FillNativeOrder::try_accounts()` frame uses a stack offset of `4112`, exceeding the `4096` byte maximum. The generated parser then traps at runtime before `handler()` can execute successfully. Any native same-chain `fill_native_order()` call fails with `ProgramFailedToComplete` and an access violation.

As a result, SVM same-chain orders cannot be filled. Solvers cannot deliver the recipient's `token_out` and receive the escrowed `token_in`; users are forced into cancellation/refund paths, and same-chain liquidity delivery is unavailable on SVM.

RECOMMENDATION

Make sure the right toolchain was used and the tests are passing before deploying the program.

PROOF OF CONCEPT https://github.com/GuardianOrg/liquidity-delivery-team1-1779205721766/blob/4ad31c9b13a36ef83a58a7af8a7d01510864f51a/svm/programs/order_book/tests/instructions/fill.rs#L523

RESOLUTION

Status: Acknowledged.

LOW **L-01**

RESOLVED

Cancel TYPEHASH diverges from EIP-712

CATEGORY	Compatibility
LOCATION	https://github.com/GuardianOrg/liquidity-delivery-team1-1779205721766/blob/22475fc629b598bf5e67a1e5ee9a66b33f657b10/evm/src/OrderBook.sol#L59-L60
REVIEW	Remediation Review

DESCRIPTION

The preimage of the `CANCEL_ORDER_TYPEHASH` includes whitespaces after the commas that separate each struct element.

```
/// @dev keccak256("CancelOrder(bytes32 orderId, address bridgeAdapter, bytes
bridgeAdapterArgs)")
bytes32 public constant CANCEL_ORDER_TYPEHASH =
0x6919f4958bcd1b5b4e13b800c6d41c4792cfc2a12d0bd9ad19da6e0bfe8ac04f;
```

This implementation is not true to the [EIP-712](https://eips.ethereum.org/EIPS/eip-712) specification, where the whitespaces are omitted.

RECOMMENDATION

Consider using `EIP-712` compliant digest if it won't break already existing integrators.

RESOLUTION

Status: Resolved.

<https://github.com/m0-foundation/liquidity-delivery/pull/72/changes/7b58b50853fbe2dcb420a33563c28ccda7b87e40>

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.